

Monitoramento do Microsoft Intune — Detecção de Ameaças

📌 **Contexto** O Microsoft Intune é uma das plataformas de gerenciamento de dispositivos móveis (MDM) mais utilizadas em ambientes corporativos. Embora seja uma ferramenta essencial para equipes de TI e Segurança (SOC), invasores podem abusar de seus privilégios para transformá-la em uma arma de distribuição de malware e destruição (como visto no recente ataque de *wiper* à empresa Stryker).

O que será abordado nesta investigação:

- Como o Intune funciona e como é utilizado pelas equipes de segurança.
- Exploração e abuso da plataforma em cenários reais de ataque.
- Monitoramento prático e detecção de ameaças utilizando o Splunk (SIEM) e logs locais do *host*.

Visão Geral do Microsoft Intune

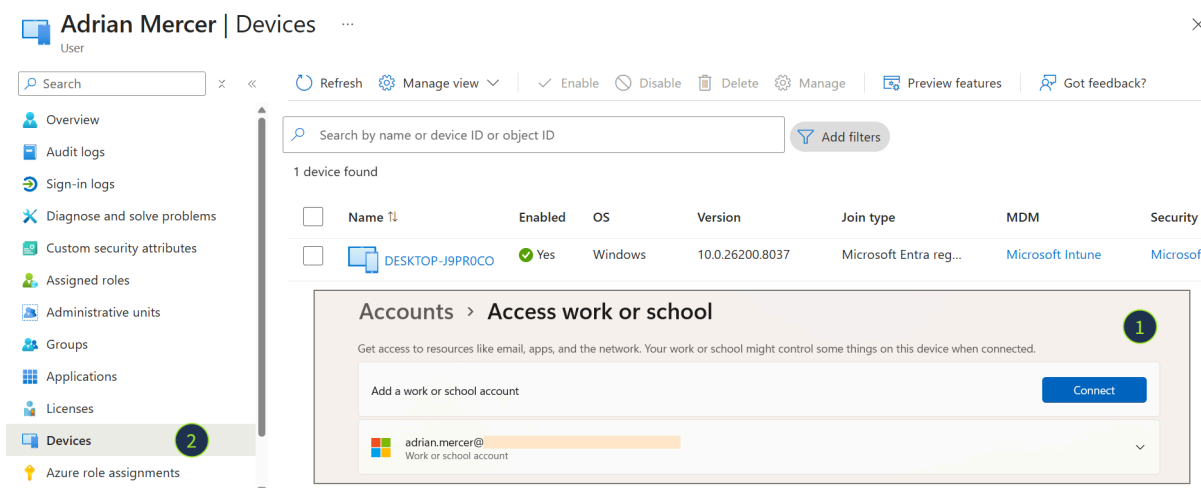
O que é o Intune

O Microsoft Intune é uma plataforma de **gerenciamento de dispositivos móveis (MDM)** baseada em nuvem. Com ele, a organização consegue auditar como dispositivos Windows, Linux, macOS e móveis são usados no ambiente, além de controlar remotamente itens como política de senha, criptografia de disco, configurações do sistema operacional e lista de permissões de aplicativos. Entre outros fornecedores de MDM conhecidos estão Jamf, JumpCloud, Atera e ManageEngine.

Como o Intune funciona

O primeiro passo é **registrar os dispositivos** no Intune, de forma manual (com acesso físico) ou remota. A maioria dos sistemas operacionais suporta registro remoto por recursos nativos, como o **ADE** no macOS e os **serviços do Google Play** no Android.

No Windows, o processo é ainda mais simples: basta **fazer login no dispositivo com o e-mail corporativo** e o dispositivo passa a aparecer no console do **Entra ID**. A partir daí, o MDM é implantado automaticamente.



Em seguida, o **agente MDM** é implantado. Embora o Intune se apresente como “sem agentes” em termos de marketing, na prática sempre há um agente instalado automaticamente em segundo plano, sem necessidade de pacotes MSI ou PKG manuais. Assim como um EDR, esse agente se conecta ao console central e fica **aguardando instruções**.

Capacidades do Intune

O Intune oferece uma ampla gama de recursos, especialmente para Windows e macOS:

- Criar um inventário de ativos de todos os dispositivos corporativos
- Enviar políticas de configuração remotamente
- Implantar e gerenciar aplicativos em toda a frota
- Limpar dispositivos em caso de infecção por malware ou roubo físico
- Aplicar regras de conformidade (por exemplo, exigir criptografia ou atualização do sistema operacional)
- Integrar com o Microsoft Entra ID (antigo Azure Active Directory)

Relevância para o analista SOC L2

Como analista SOC L2, o Intune aparece em vários cenários:

Uso	Para quê
Inventário de ativos	Obter mais informações sobre o dispositivo investigado
Correção/desinstalação de software	Agir rapidamente em grandes incidentes de cadeia de suprimentos

Aplicação de políticas e verificações

Executar checagens de segurança ou instalar agentes de EDR/SIEM em massa

Isolamento e reimagem

Isolar dispositivos da rede ou reinstalar o sistema operacional em caso de roubo

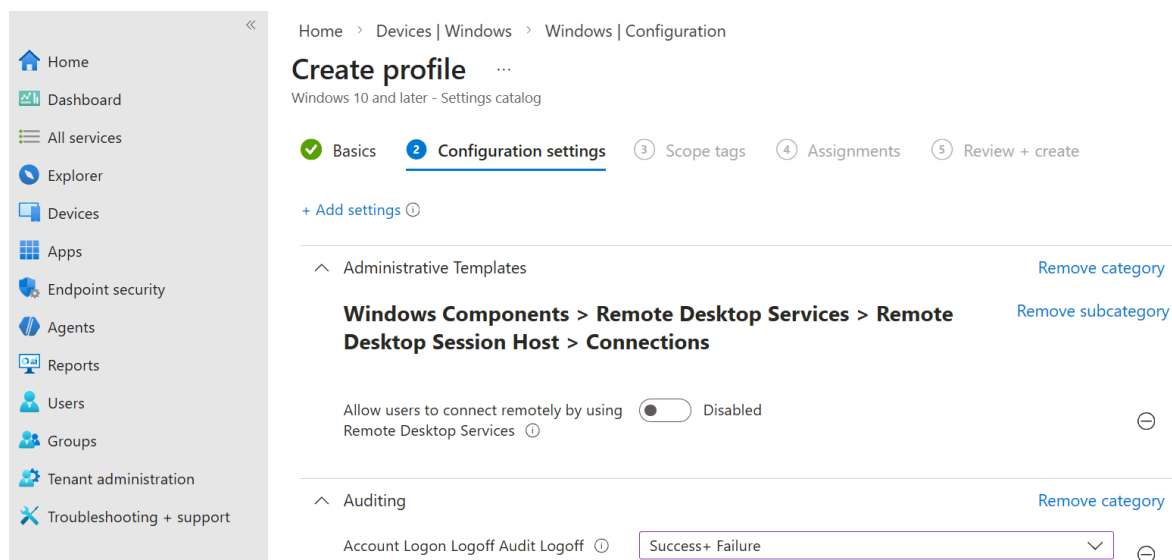
Intune para Equipes de Segurança

Portal do Intune

Os dispositivos integrados podem ser organizados em grupos e gerenciados no console em nuvem do Intune (<https://intune.microsoft.com/>), onde é possível definir políticas, implantar scripts, instalar aplicativos e configurar a inscrição automática. A licença já está incluída nas assinaturas **Microsoft 365 E3 e E5**, sem custo adicional para quem já gerencia usuários no Entra ID.

Gerenciamento de Dispositivos

Como analista SOC, é improvável que eu aplique configurações no Intune sozinho, mas a maioria das configurações do sistema operacional pode ser aplicada remotamente por ele. O recurso **Dispositivos > Configuração** permite aplicar boas práticas, como desativar o RDP em estações de usuários comuns ou habilitar a auditoria de logon/logoff em todos os endpoints.



Conformidade do Dispositivo

O Intune rotula ativos como **compatíveis ou não compatíveis** e, junto com o **Acesso Condicional**, restringe o acesso a recursos em nuvem como a caixa de correio e o SharePoint. Caso de uso: permitir que apenas dispositivos conhecidos e reforçados acessem o M365 corporativo.

1. **Política de conformidade:** o dispositivo é marcado como não conforme se não tiver BitLocker habilitado, não tiver o Microsoft Defender EDR instalado ou se a senha do usuário for fraca.
2. **Política de Acesso Condicional:** bloqueia o acesso ao M365 quando o login vem de um dispositivo desconhecido (não inscrito no Entra ID ou Intune) ou não conforme.

Contexto do Dispositivo e SIEM

Nos logs de login via Entra ID, a Microsoft inclui os detalhes do dispositivo, o que permite ao SOC identificar o tipo usado:

Situação	O que o log mostra
Dispositivo não gerenciado	Campo <code>deviceDetail</code> vazio
Dispositivo unido ao Entra ID	Subcampo <code>trustType</code>
Dispositivo gerenciado pelo Intune	Subcampos <code>isCompliant</code> e <code>isManaged</code>

9 em cada 10 ataques ao M365 partem de dispositivos não gerenciados (`deviceDetail` vazio). Um ataque vindo de dispositivo gerenciado normalmente indica ameaça interna ou dispositivo infectado/roubado.

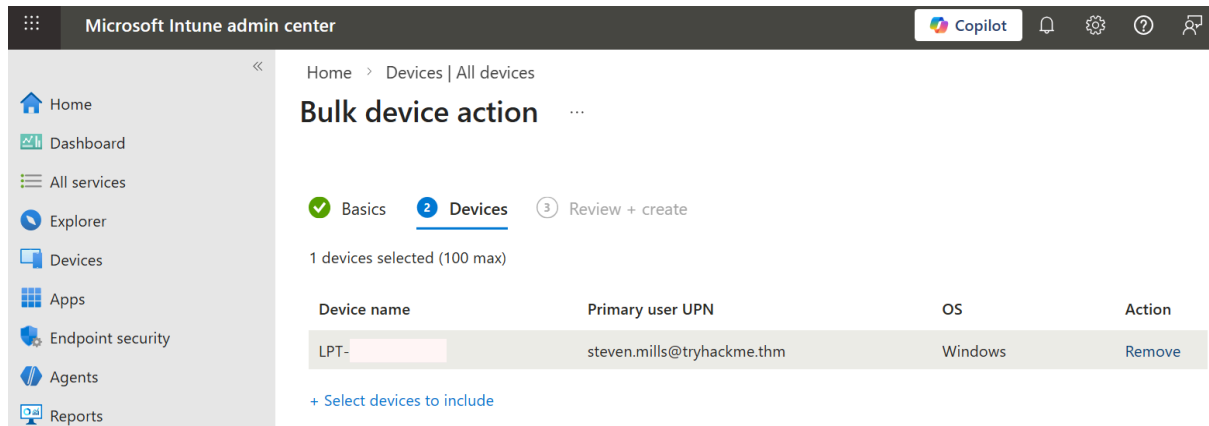
Riscos do Intune: Limpeza Remota

O ataque ao Stryker

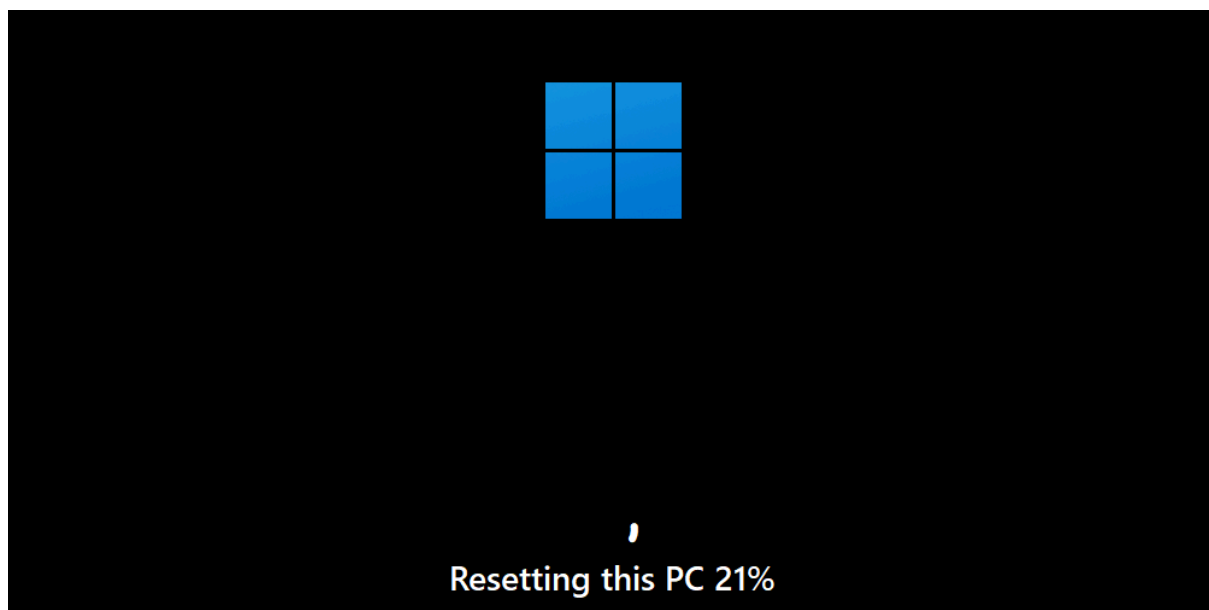
Nas mãos erradas, o console do Intune pode virar um servidor de Comando e Controle completo ou uma arma de destruição em massa de dados. Em **11 de março de 2026**, agentes de ameaça supostamente comprometeram uma conta administrativa M365 da **Stryker**, gigante de tecnologia médica sediada nos EUA, e emitiram um comando de **limpeza remota** do Intune em quase **80.000 dispositivos**. Em poucas horas os dados foram apagados, causando grande interrupção nas operações.

Como isso foi possível

O Intune suporta **ações em massa** em todos os dispositivos inscritos: reiniciar, renomear e limpar. Com acesso administrativo ao console, qualquer usuário pode emitir o comando de limpeza em todas as plataformas, **exceto Linux**. Assim que o agente recebe o comando, o dispositivo é redefinido para as configurações de fábrica, apagando os dados locais. Foi essa funcionalidade que foi transformada em arma.



Dispositivos > Ação de dispositivo em massa > Limpar



“Redefinindo este PC” cerca de 1 minuto depois

Monitoramento da limpeza remota

Não faz sentido criar uma regra de SIEM como “limpeza em massa via Intune”: quando o SOC receber o alerta, a limpeza já terminou, pois não há forma documentada de abortar o comando. Por isso, o foco é a linha do tempo que antecede o ataque.

1. Login no Intune

O primeiro estágio é detectar logins no portal. No mínimo, alertar sobre logins de administradores do Intune vindos de **dispositivos não gerenciados**, **IPs suspeitos** ou **fora do horário de trabalho**. Os logs de login do Entra ID registram cada acesso com **appDisplayName** igual a “extensão do portal Microsoft Intune”.

```
1 index=intune sourcetype=azure:aad:signin appDisplayName=*Intune* deviceDetail.displayName=""
2 | rename deviceDetail.* as dvc.*
3 | table _time appDisplayName ipAddress dvc.isManaged dvc.isCompliant dvc.displayName user
```

✓ 15 events (before 10/9/26 9:12:24.000 PM) No Event Sampling

Events Patterns **Statistics (15)** Visualization

Show: 20 Per Page Format Preview: On

_time	appDisplayName	ipAddress	dvc.isManaged	dvc.isCompliant	dvc.displayName	user
2026-03-17 19:19:28	Microsoft Intune portal extension	149.40.62.43	false	false		steven.mills@tryhackme.thm
2026-03-17 19:19:28	Microsoft Intune portal extension	149.40.62.43	false	false		steven.mills@tryhackme.thm
2026-03-17 19:19:28	Microsoft Intune portal extension	149.40.62.43	false	false		steven.mills@tryhackme.thm
2026-03-17 19:19:28	Microsoft Intune portal extension	149.40.62.43	false	false		steven.mills@tryhackme.thm
2026-03-17 19:19:28	Microsoft Intune portal extension	149.40.62.43	false	false		steven.mills@tryhackme.thm

Um adversário avançado também pode usar o Intune via **Graph API**, detectável quando alguém consente o aplicativo com permissões OAuth

DeviceManagementManagedDevices.* ou **DeviceManagementConfiguration.***.

Nesta sala o foco é o caminho mais comum: o acesso pelo navegador.

spl

```
index=intune sourcetype=azure:aad:signin appDisplayName=*Intune*
deviceDetail.displayName=""
```

```
| rename deviceDetail.* as dvc.*
```

```
| table _time appDisplayName ipAddress dvc.isManaged dvc.isCompliant dvc.displayName
user
```

2. Comando de limpeza

O último ponto de detecção já é a própria limpeza. Os comandos aparecem em **Administrador do locatário > Logs de auditoria do Intune**, em tempo real. Diferente do Entra ID e do M365, esses logs **não podem ser ingeridos diretamente no SIEM**: é preciso usar a Graph API ou rotear via Azure Event Hub.

Cada registro traz o ator e o tipo de atividade, que nas limpezas é **wipe ManagedDevice**. O log mostra o **ID do dispositivo**, não o hostname. Esse ID pode ser correlacionado com outros eventos históricos, como **Adicionar dispositivo** nos logs de auditoria do Entra ID, para descobrir o hostname, o ID de hardware e a versão do SO do dispositivo apagado.

spl

```
index=intune sourcetype="o365:graph:intune" wipe
```

```
| eval deviceid=mindex('resources{}.modifiedProperties{}.newValue', 0)
```

```
| table _time activityType actor.userPrincipalName deviceid
```

Questões Respondidas

Qual é o ID do dispositivo apagado?

Resposta: **d66b71f3-a644-4392-89b2-d97ba5612356**

Obtido com a consulta de limpeza acima, no campo **deviceid**.

Qual é o nome do host do dispositivo Windows apagado?

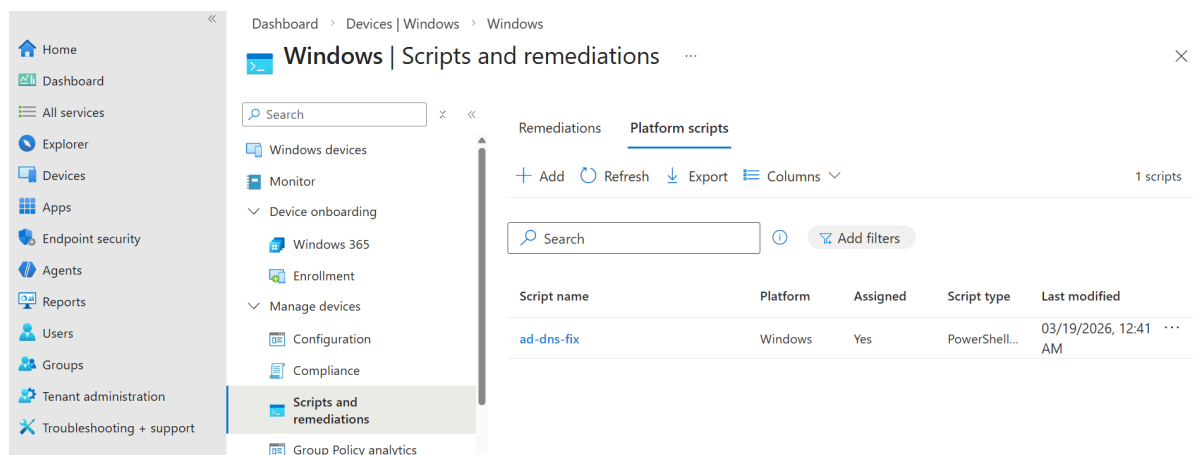
Resposta: **LPT-08312**

Como o log de limpeza traz apenas o ID, o hostname é obtido correlacionando esse ID com o evento “Adicionar dispositivo” dos logs de auditoria do Entra ID.

Scripts de Plataforma e Implantação de Aplicativos no Intune

Scripts de plataforma

A limpeza remota não é a única arma de um invasor com acesso ao Intune. A plataforma também permite implantar **scripts personalizados** (como PowerShell) e executá-los no contexto do usuário conectado ou da conta **SYSTEM** local. Para administradores, é útil para comandos únicos em massa; para um agente de ameaça, é fácil implantar um *infostealer* em PowerShell em todos os dispositivos.



Não há proteção contra comandos maliciosos nem notificação por e-mail à equipe de TI, então o **monitoramento de logs** é o caminho.

Artefatos no SIEM

O ciclo de vida do script tem quatro estágios: **criado** no console, **atribuído** aos dispositivos, **executado** nos dispositivos e **excluído** pelo TI. Dá para acompanhar esses estágios no SIEM filtrando por `activityType=*DeviceManagementScript*`.

<pre> 1 index=intune sourcetype="o365:graph:intune" activityType=*DeviceManagementScript* 2 eval action=mvindex(split(activityType, " "), 0) 3 eval script='resources{}.resourceId' 4 eval target=mvindex('resources{}.modifiedProperties{}.newValue', 0) 5 eval target=if(action="assignDeviceManagementScript", target, "N/A") 6 table _time actor.userPrincipalName action script target </pre>					All time
✓ 3 events (before 10/9/26 9:48:55.000 PM) No Event Sampling					Job Smart Mode
Events Patterns Statistics (3) Visualization					
Show: 20 Per Page Format Preview: On					
_time	actor.userPrincipalName	action	script	target	
2026-03-17 18:57:56.800	steven.mills@tryhackme.thm	createDeviceManagementScript	24db5bd7-571b-468e-8def-b20a01b2bf0a	N/A	
2026-03-17 18:57:57.360	steven.mills@tryhackme.thm	assignDeviceManagementScript	24db5bd7-571b-468e-8def-b20a01b2bf0a	adadadad-808e-44e2-905a-0b7873a8a531,acacacac-9df4-4c7d-9d50-4ef0226f57a9	
2026-03-17 18:57:16.612	steven.mills@tryhackme.thm	deleteDeviceManagementScript	c0709410-f1e0-4619-ac73-eca347ca1b8b	N/A	

Alguns IDs de destino são específicos do ambiente (grupo ou host), enquanto outros são conhecidos: por exemplo, **adadadad-808e-44e2-905a-0b7873a8a531** significa **All Devices**.

spl

```
index=intune sourcetype="o365:graph:intune" activityType=*DeviceManagementScript*
```

```
| eval action=mvindex(split(activityType, " "), 0)
```

```
| eval script='resources{}.resourceId'
```

```
| eval target=mvindex('resources{}.modifiedProperties{}.newValue', 0)
```

```
| eval target=if(action="assignDeviceManagementScript", target, "N/A")
```

```
| table _time actor.userPrincipalName action script target
```

Pergunta: quando o script foi implantado nos alvos?

Resposta: **2026-03-17 18:57:57**

Obtido na linha da ação **assignDeviceManagementScript** desta consulta.

Artefatos no host

Como todo MDM é baseado em agente, no Windows o Intune executa scripts por uma árvore de processos específica, monitorável pelo evento de segurança **4688** ou, melhor, pelo **Sysmon Evento 1**. Em Linux e macOS a cadeia é semelhante, com imagens próprias de cada plataforma.

Microsoft.Management.Services.IntuneWindowsAgent.exe

└─ AgentExecutor.exe

└─ powershell.exe -NoProfile -executionPolicy bypass -file
 "...\\Policies\\Scripts\\<random-uuid>.ps1"

Após a execução, o script é removido do diretório de preparação, mas os rastros permanecem no `AgentExecutor.log`, em `C:\ProgramData\Microsoft\IntuneManagementExtension\Logs`. Esse arquivo é valioso na forense porque registra:

Informação	Observação
Hora de execução	No teste do material, ~30 minutos após a criação
Duração da execução	Eventos separados para implantação, início e conclusão
Saída ou erro em texto simples	Mostra o resultado do script

```
3/17/26      <![LOG[write output done. output = THM{hello_world_from_intune!}, error = ]LOG]!><time="19:24:41.4587157" date="3-7:24:41.458 PM" component="AgentExecutor" context="" type="1" thread="1" file="">
             host = PC-096 | source = AgentExecutor.log | sourcetype = custom:intune:winexecutor
```

Pergunta: qual é a saída do script implantado no PC-096?

Resposta: `THM{hello_world_from_intune!}`

Encontrada no `AgentExecutor.log` do dispositivo.

Implantação de aplicativos

Um cenário mais avançado é empacotar malware em um aplicativo no formato `.intunewin` (ou `.dmg/.pkg` no macOS) e implantá-lo com os privilégios mais altos, **mesmo sem assinatura de uma autoridade confiável**. Isso abre espaço para ransomware, mineradores de criptomoedas e exfiltração de dados em escala.

Add App ...

Windows app (Win32)



✓ Program ✓ Requirements ✓ Detection rules ✓ Dependencies ✓ Supersede 7 Assignments ...

i Any Win32 app deployed using Intune will not be automatically removed from the device when the device is retired. The app and the data it contains will remain on the device. If the app is not removed prior to retiring the device, the end user will need to take explicit action on the device to remove the app.

Required ⓘ

Group mode	Group	Status	Filter mode	Filter	End user notifications	Availa
+ Included	All devices	Active	None	None	Show all toast notifications	As so

+ Add group ⓘ + Add all users ⓘ + Add all devices ⓘ

spl

```
index=intune sourcetype="o365:graph:intune" activityType=*MobileApp*
```

Reforço da Segurança do Intune

Lições do caso Stryker

O ataque do limpador foi devastador, mas **trivial de executar**: bastaram credenciais válidas de um único funcionário com acesso administrativo ao portal Intune. Embora não confirmado, internautas já encontraram credenciais de administrador da Stryker expostas, o que torna crível que os adversários as obtiveram via **phishing AiTM** ou **dumps de infostealers**. A lição central: **proteger as contas de administrador**.

Protegendo contas administrativas

A primeira linha de defesa contra uma limpeza em massa é controlar o acesso a contas privilegiadas: Administradores Globais, Administradores do Intune e qualquer função com permissão de limpeza. As principais medidas, já vistas na sala de Monitoramento do Entra ID:

- **Acesso Condicional** para impedir logins de dispositivos e países inesperados
- **Proteção de Identidade** para alertar sobre logins arriscados ou desativar automaticamente contas de alto risco
- **Logs de login e auditoria do Entra ID** para alertar sobre viagens impossíveis e outras anomalias
- Ter **menos de 5 Administradores Globais**, independentemente do tamanho da empresa
- Impor **chaves de acesso ou MFA por hardware** em todas as contas privilegiadas
- Usar o **PIM (Gerenciamento de Identidade Privilegiada)** para tarefas administrativas

Recursos de segurança do Intune

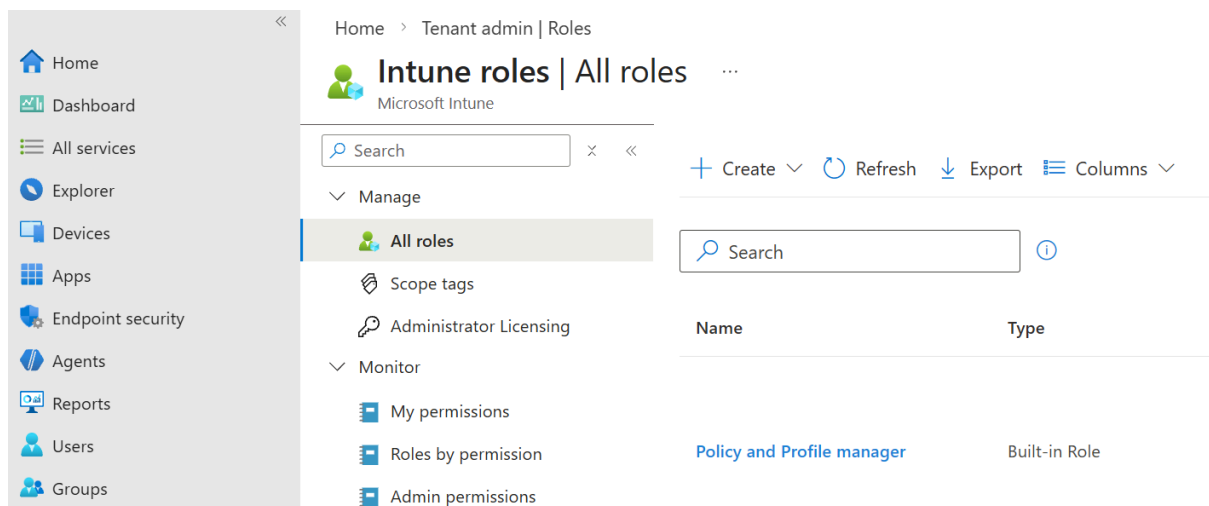
Incidentes acontecem e contas são comprometidas, e um único controle nunca basta. Para limitar o impacto, o ideal é preferir **funções personalizadas** às funções padrão do Intune, que são amplas e podem ser abusadas por um invasor.

Exemplo de estrutura empresarial

Equipe	Uso do Intune
Segurança (4 pessoas)	Limpeza remota de dispositivos roubados, ~1 vez por ano
TI global (6 pessoas)	Scripts de plataforma, ~1 vez por mês
Helpdesk da UE (10 pessoas)	Instala aplicativos e altera políticas em dispositivos da UE
Helpdesk dos EUA (10 pessoas)	Mesmo fluxo, apenas em dispositivos dos EUA

O caminho de menor resistência é dar a função de **Administrador do Intune** a todos, resultando em **30 contas capazes de iniciar uma limpeza em massa**. A alternativa mais segura é criar quatro funções personalizadas:

- **Segurança:** pode limpar dispositivos
- **TI global:** pode executar scripts de plataforma
- **Operador de Helpdesk:** pode instalar aplicativos
- **Administrador de Helpdesk:** instala aplicativos e altera políticas



Tags de escopo

Os privilégios podem ser reduzidos ainda mais com **tags de escopo**, que rotulam recursos e restringem o acesso com base nesses rótulos. No cenário acima, as estações são marcadas por região (UE e EUA) e as funções de Helpdesk são divididas em variantes de cada região, cada uma restrita aos ativos que precisa gerenciar.

Dashboard > Tenant admin | Roles > Intune roles

Intune roles | Scope tags

Microsoft Intune

Search

Manage

- All roles
- Scope tags**
- Administrator Licensing

Monitor

- My permissions
- Roles by permission
- Admin permissions

Help and support

- Help and support

Scope tags define groups of Intune resources that align with specific Intune Role assignments. For example, a "Seattle Office" scope tag could be used to associate policies, profiles or applications with administrators that only apply to the Seattle office location.

+ Create Refresh Export Columns 3 items

Search

Name	Description
Default	By default, all Intune entities without scope tag are assigned to this built-in scope tag. ...
EU	...
US	...

Aprovação de vários administradores

Para operações raras e críticas, como scripts de plataforma e limpezas remotas, é possível exigir **aprovação de vários administradores**. No cenário, a TI aprovaria as limpezas e a segurança aprovaria os scripts. É importante que apenas **um ou dois Administradores Globais** possam editar as políticas de aprovação, e não toda a TI.

Dashboard > Tenant admin | Multi Admin Approval

Create an access policy

Basics 2 Approvers 3 Reviewers

Name *

Description

Policy type * 1

App

Compliance policy

Configuration policy

Device delete

Device retire

Device wipe

Role

Script

Tenant configuration

App

An app policy will require approval for applications, such as mobile apps or built-in apps. This could include create, edit, assign, and delete. App policies can be limited to only Windows platforms, non-Windows platforms, or can apply to all platforms.

Previous Next

Conclusão

Este é o fim da documentação da sala de Microsoft Intune.

O Intune é essencial para que as equipes de TI e segurança centralizem o gerenciamento de dispositivos e apliquem políticas remotamente. Nas mãos erradas, porém, pode se tornar uma ferramenta de ataque perigosa, semelhante a outras como EDR e RMM. Ao longo desta documentação, vi como monitorar o Intune, desde os logins no portal até limpezas remotas, scripts de plataforma e implantação de aplicativos, e como protegê-lo com contas administrativas reforçadas, funções personalizadas, tags de escopo e aprovação de vários administradores.

Obrigado por ler e acompanhar esta investigação!